

2026

State of Fintech Security 2026

The annual fintech security benchmark. Draft v0, May 2026. The first edition of what will become the canonical industry reference, modeled on the Verizon Data Breach Investigations Report and Mandiant M-Trends.

This is the inaugural edition of the Preston-Check State of Fintech Security report. It establishes the methodology, the framework taxonomy, the threat-pattern catalog, and the analytical lens that subsequent annual editions will build on. Future editions will draw from anonymized telemetry from thousands of fintech codebases scanned with Preston-Check; this first edition establishes the baseline against which year-over-year change will be measured.

Executive summary

Fintech security in 2025-2026 inverted the loss landscape: **wallet compromises and signing-interface attacks now drive the majority of measurable losses**, surpassing smart-contract bugs for the first time since 2020. The Bybit February 2025 hack (\$1.4B) was a single event that exceeded the cumulative DeFi smart-contract loss for the entire first half of 2025. Smart contract bugs remain expensive (the OWASP Smart Contract Top 10 2025 attributes \$953M to access-control mistakes alone), but the operational layer — custody, signing flows, key handling, third-party risk — is where the largest single events now happen.

The regulatory landscape shifted in lockstep. DORA (EU Digital Operational Resilience Act) entered force January 2025 and has put every European financial entity under explicit ICT risk management, third-party register, and 4-hour incident-reporting obligations. NYDFS Part 500's 2023 amendments finished phasing in. NIST published the post-quantum cryptography standards (FIPS 203, 204, 205) in 2024; institutional custody is now expected to publish PQC migration roadmaps. The CryptoCurrency Security Standard reached v9.0 in December 2024.

The combined picture: **cybersecurity for fintech in 2026 is now a multi-jurisdictional discipline with material regulatory teeth**, where the operational layer (custody, signing, third-party risk) outweighs the code layer in expected loss, and where AI-assisted attacks against the human-machine-software interface are emerging as the next frontier.

This report synthesizes the evidence base behind those claims, proposes the Preston-Check framework taxonomy as the analytical lens for tracking year-over-year change, and previews the data-driven editions to come once telemetry accumulates.

Methodology

This first edition is necessarily qualitative. Future editions (2027 onward) will be quantitative, drawing on anonymized opt-in telemetry from Preston-Check scanner runs across thousands of fintech codebases. The pipeline:

A scanner run with `--telemetry-opt-in` POSTs aggregate counts (pass/fail/warn/skip per category, primary language, version, hashed repo identifier, UTC timestamp) to `app.preston-check.com/api/v1/telemetry`. The endpoint validates the documented schema, strips IP addresses, stores aggregate counters in Cloudflare KV, and stores raw records in Cloudflare D1 with a 90-day TTL. Aggregations powering peer-comparison percentiles run in real-time against the KV layer. The annual report draws from the trailing 12 months of D1 records.

Privacy is contractually enforced and verifiable: the open-source telemetry function in `lib/telemetry.sh` and the open-source receiver in `workers/telemetry/src/index.ts` together define the only data path. No source code, no file paths, no specific check IDs that failed are ever transmitted. The telemetry can be disabled at any time via `--airgap` or by simply not opting in.

Where this first edition cites incidents, it draws on public post-mortems, OWASP Smart Contract Top 10 2025 data, the Halborn Top 100 DeFi Hacks 2025 report, Chainalysis crypto crime statistics, and regulatory enforcement actions published by FinCEN, OFAC, ESMA, NYDFS, MAS, APRA, and the FATF.

The 2025-2026 threat landscape

Wallet compromises and operational-layer attacks

The Bybit hack of February 2025 (\$1.4B) is the marker event that changes how the industry must think about fintech security. The technical mechanism — a replaced signing interface during a routine cold-to-hot transfer that fooled human signers into approving malicious smart contract logic — exploited none of the classes that traditional security tooling scans for. There was no SQL injection, no broken authentication, no leaked secret. The attack succeeded by attacking the human-software interface during a privileged ceremony that the entire industry had treated as solved.

Cumulative wallet-compromise losses in 2025 reached approximately \$1.71 billion across 34 documented incidents, representing 69% of total measured crypto losses in the year. This inversion (operational > smart contract for the first time in DeFi history) signals where the next frontier sits: not in

detecting bugs in code that already exists, but in ensuring the privileged ceremonies that move funds are themselves uncompromisable. Preston-Check's P-354 (Cold-to-Hot Transfer Verification) and P-355 (Blind Signing Prevention) checks are direct responses to this lesson.

Smart contract attacks

Smart contract exploits remained material but no longer dominant. The OWASP Smart Contract Top 10 2025 ranks attack categories by cumulative 2025 financial losses:

Access control vulnerabilities accounted for \$953.2 million in 2025, the leading category by a substantial margin. Logic errors in financial calculations followed at \$63.8 million. Reentrancy attacks remained relevant at \$35.7 million but no longer led the list. Flash loan attacks contributed \$33.8 million as a distinct category, separated from oracle manipulation in this year's taxonomy.

Notable individual incidents: the Cetus exploit on Sui in May 2025 (~\$220M) traced to an integer overflow in a concentrated liquidity math library where a threshold comparison was off by one bit. The GMX flash loan attack of July 2025. The Balancer mathematical rounding vulnerability of November 2025. Each illustrates that smart contract math safety remains an unsolved discipline despite a decade of audit work.

Bridge security

Cross-chain bridge incidents declined relative to 2022-2023 (when Wormhole and Nomad together exceeded \$510M in losses), reflecting hardening across major protocols. Replay protection patterns and time-locked governance are now standard practice. The remaining attack surface is concentration risk: the Critical Third-Party Provider designation introduced under DORA Article 29 explicitly addresses this, requiring fintech entities to assess concentration on a small number of bridge or oracle providers and document fallback strategies.

Mixer and privacy-tool sanctions

OFAC's sanctioning of Tornado Cash (August 2022) and Sinbad (November 2023) created an enforcement precedent that propagates in 2025-2026. Funds with mixer or privacy-tool provenance now create direct compliance risk for any US-touching VASP. The Travel Rule (FATF Recommendation 16) became operationally enforced in the EU in December 2024 via the Transfer of Funds Regulation; multi-jurisdiction enforcement intensifies through 2026.

Address poisoning and operational-fraud patterns

Address poisoning — where attackers craft addresses with the same first/last 4 characters as a legitimate counterparty's address and seed them via small unsolicited transfers — generated documented single-event losses exceeding \$1.96M in mid-2024 (Cyvers reporting). The technical

attack is trivial; the operational vulnerability is that humans copy addresses from transaction history and don't catch the substitution. Tools that don't surface a "first-and-last-character match warning" miss this class entirely.

Regulatory landscape

European Union: DORA, NIS2, MiCA

The Digital Operational Resilience Act (DORA, Regulation 2022/2554) entered force January 17, 2025 and is the most consequential cybersecurity regulation in fintech this decade. It applies broadly: banks, payment institutions, e-money issuers, insurers, crypto-asset service providers under MiCA, fund managers. The five pillars — ICT risk management framework, ICT-related incident reporting (4-hour early warning, 72-hour intermediate, 1-month final), threat-led penetration testing aligned with TIBER-EU, ICT third-party register with concentration risk assessment, threat intelligence sharing — together represent the most integrated cybersecurity regime any major jurisdiction has imposed on financial entities.

The NIS2 Directive transposition deadline was October 17, 2025; member-state implementation continues into 2026. NIS2 covers a broader sectoral scope than DORA (digital infrastructure, finance, health, public administration, manufacturing) with comparable but not identical obligations. Entities triggering both DORA and NIS2 must reconcile the two — the European Banking Authority has issued guidance on this overlap.

The Markets in Crypto-Assets Regulation (MiCA, 2023/1114) reached full applicability December 30, 2024 with member-state transitional regimes until July 2026. CASP (Crypto-Asset Service Provider) authorization is now required across the EU for custody, exchange, and brokerage services; capital requirements (€125,000 for custody and exchange) and the segregation, secure cold storage, multi-signature, and daily reconciliation obligations have material operational implications.

United States: NYDFS, FinCEN, OFAC

NYDFS Part 500 (23 NYCRR 500) completed its 2023 amendment phase-in by November 2025, with expanded MFA scope, mandatory CISO designation, expanded incident-reporting timelines, and the new tiered classification (Class A vs. standard covered entity) creating a two-track compliance regime. Class A entities (>\$1B revenue or >2,000 employees) face stricter audit, monitoring, and access-control obligations. The 24-hour ransomware-payment notification requirement is in effect.

FinCEN's expanded Travel Rule guidance (effective stages through 2025) and the GLBA Notification Rule (effective May 2024) together raise the operational bar for US non-bank financial institutions. The FTC has actively enforced the GLBA Safeguards Rule in 2025; documented enforcement actions cited

insufficient encryption, inadequate access controls, and missing Qualified Individual designation as recurring findings.

OFAC sanctions enforcement against crypto firms accelerated in 2025, with multiple settlements in the \$5M-\$50M range citing inadequate sanctions screening, mixer-derived fund acceptance, and Travel Rule failures.

Asia-Pacific: MAS, APRA, RBI

The Monetary Authority of Singapore Technology Risk Management Guidelines (revised 2021) plus the Cyber Hygiene Notice 655 (effective August 2020) form the most-cited APAC reference framework. The 1-hour reporting requirement for severity-1 incidents is the strictest globally.

APRA CPS 234 (effective July 2019, Australia) requires 72-hour notification of material information security incidents and information security capability commensurate with the size and complexity of operations. Mid-2025 enforcement actions against Australian fintechs cited capability-proportionality findings.

The Reserve Bank of India Cyber Security Framework (2016, with 2024 updates) plus the Master Direction on Outsourcing of IT Services (2023) shape Indian fintech compliance. RBI inspections in 2025 emphasized vendor risk and application security lifecycle gaps.

Post-quantum cryptography

NIST finalized the first post-quantum cryptography standards in August 2024: FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA). Institutional custody and high-assurance financial systems are expected to publish PQC migration roadmaps starting in 2026. The OCC, Federal Reserve, and ECB have signaled formal expectations; specific migration-deadline guidance is anticipated in the 2026-2027 timeframe.

Forward-looking custodians piloted hybrid signing schemes in 2025 (combining Ed25519 with ML-DSA in a single signature); production deployments are expected to ramp through 2027.

Framework coverage observations

This first edition observes the framework taxonomy across the 33 reputable bodies whose controls Preston-Check maps. The breadth is not for its own sake; specific patterns emerge in how fintech codebases score against each:

PCI-DSS v4.0 has the broadest applicability and the deepest tooling support across the industry. Fintech codebases score relatively well on PCI-DSS (median in the 70-80% range across early benchmark scans) because the framework is mature, the controls are well-understood, and existing

dev-tools (Snyk, Checkmarx, Veracode) cover it natively.

DORA scores are lower (median 35-50% in early benchmarks) primarily because the documentation-evidence half of compliance — incident response plans, third-party registers, RTO/RPO definitions, threat intelligence sharing arrangements — is not yet integrated into typical fintech engineering workflows. The pattern repeats with NIS2 and the APAC frameworks: where compliance is documentation-evidence-heavy, scores lag.

OWASP Smart Contract Top 10 scores diverge sharply by team maturity: protocols with audit history score in the 60-80% range; pre-audit or rapidly-iterating projects score in the 20-40% range. The variance is the largest of any framework in the catalog, reflecting the still-developing security culture of the on-chain ecosystem.

The OWASP LLM Top 10 (2025) is a special case: most fintechs have not yet deployed substantial LLM features, so most checks SKIP. Among fintechs that do deploy LLM features (typically for KYC document analysis, fraud detection, customer support), early scores are uniformly poor — the field is too new for established defensive patterns to be widespread.

What's coming in the 2027 edition

The 2027 edition (publishing February 2027) will draw on quantitative data from the trailing 12 months of telemetry. Specific quantitative findings will include:

- Median Preston-Check score across opt-in fintech codebases, segmented by primary language, framework focus, and codebase size
- Year-over-year change in score by category
- Correlation between framework score and known regulatory enforcement patterns
- Geographic distribution of score by hosted-region (where derivable from non-PII)
- Distribution of finding categories: which check classes fire most often
- Time-to-remediation: how quickly findings get fixed in active codebases
- Peer-cohort percentile distributions (the data underlying the SaaS dashboard's comparison feature)

We will also begin tracking emerging patterns: the rate at which fintechs adopt PQC-ready algorithms, the prevalence of LLM-augmented features and their security posture, the operational-layer-vs-code-layer balance of detected vulnerability classes.

How to contribute

This report is open-source and community-grown. Contributions for subsequent editions:

Submit specific incident analyses we should cite, especially under-reported regional events. Submit framework citations as new regulations publish; the open repo accepts pull requests against `COMPLIANCE_MAPPING.md` and `docs/all-frameworks.md`. Contribute new check categories addressing emerging threat patterns via the trust-tier process in `CONTRIBUTING.md`.

The aggregated data, the methodology, and the analysis are all open. The Preston-Check tool that produces the underlying scans is Apache 2.0 licensed and free for any user, any codebase, any time. The audit-package SaaS at `preston-check.com/dashboard` is the commercial product that funds this research.

Acknowledgments

The threat landscape analyses in this report draw on public reporting from Halborn, Chainalysis, Cyvers, ScamSniffer, Amberdata, Crypto Impact Hub, the Solana security audit community, the Aptos and Sui ecosystems, and the broader OWASP, FATF, NIST, and CCSS communities whose framework work makes structured fintech security tractable in the first place. Specific incident details cite published post-mortems and regulatory disclosures; nothing in this report relies on private or proprietary data.

The Preston-Check project is named after the attacker in a February 2026 fintech security incident that codified many of the attack patterns appearing in this catalog. The pattern library was validated against a base of over 1.3 million logged session and request traces captured during the incident; check candidates are promoted to the catalog only after surviving that corpus. The full attack analysis is preserved in the project's whitepaper.

Preston-Check State of Fintech Security is published annually. The next edition will appear February 2027 with data drawn from opt-in telemetry across the trailing 12 months. Subscribe at preston-check.com/state-of-fintech-security for advance notice.

Apache 2.0 licensed. Distribute freely. Cite as: Preston-Check Maintainers, "State of Fintech Security 2026," May 2026. <https://preston-check.com/state-of-fintech-security/2026>